RELATÓRIO TÉCNICO DE VULNERABILIDADES

CVEs recentes da Microsoft

Patch Tuesday de outubro de 2026 (13/10/2026)

Inclui o zero-day explorado CVE-2026-96951 (Windows Shell / Mark of the Web)

Data de referência: 22 de outubro de 2026
Escopo: ~1.410 CVEs no mês — 3 zero-days e 21 CVEs críticas/prioritárias analisadas em detalhe
Fonte primária: Microsoft Security Response Center (Security Update Guide / API MSRC)
e Windows message center; contexto de CISA KEV e pesquisadores (ZDI, Tenable, BleepingComputer)

Documento de estudo. CVSS, CWE, avaliação de explorabilidade e descrições vêm dos registros oficiais do MSRC; contagens e contexto de terceiros estão identificados. Confirme sempre no Security Update Guide antes de agir.

Sumário

1. Sumário executivo 3

2. Contexto e conceitos 5

3. Zero-days 6

3.1 CVE-2026-96951 — Windows Shell: bypass do Mark of the Web (explorada) . . . 6

3.2 CVE-2026-108398 — .NET Framework: bypass do WDAC (divulgada) . . . 7

3.3 CVE-2026-92707 — MessagePack-CSharp: negação de serviço (divulgada) . . . 7

4. CVEs críticas 9

4.1 CVE-2026-70242 — Outlook: RCE pelo Painel de Leitura . . . 9

4.2 CVE-2026-96934 — DHCP Server: RCE sem autenticação . . . 10

4.3 CVE-2026-100202 — Message Queuing: RCE sem autenticação . . . 10

4.4 CVE-2026-105016 — Microsoft QUIC: RCE sem autenticação . . . 11

4.5 CVE-2026-70187 — Remote Desktop Gateway: RCE sem autenticação . . . 11

4.6 CVE-2026-70229 — Active Directory Domain Services: RCE . . . 12

4.7 CVE-2026-70571 — Exchange Server: RCE via e-mail . . . 12

4.8 CVE-2026-102866 — SharePoint: elevação de privilégio . . . 13

4.9 CVE-2026-102214 — Hyper-V: escape da VM para o host . . . 13

5. CVEs “Importantes” de alta prioridade 14

5.1 CVE-2026-70279 — Exchange: spoofing via XSS . . . 14

5.2 CVE-2026-96940 — Exchange: acesso a caixas de outros usuários . . . 14

5.3 CVE-2026-65674 — SQL Server: RCE autenticada . . . 15

5.4 Outras “Importantes” com exploração mais provável . . . 15

6. Mudanças de hardening e fins de suporte 16

7. Recomendações práticas para o suporte 16

Apêndice A — Outras CVEs críticas citadas 18

Fontes de pesquisa 18

1. Sumário executivo

Em 13 de outubro de 2026 a Microsoft publicou o maior Patch Tuesday da sua história: entre **1.407 e 1.417 CVEs**, conforme o método de contagem de cada empresa de segurança, contra cerca de 980 em setembro e cerca de 180 em outubro de 2025. Mais de 1.100 delas estão no Windows. Diante desse volume, este relatório analisa em detalhe o que importa para priorizar: **os 3 zero-days** (1 explorado ativamente e 2 divulgados publicamente antes da correção) e **21 CVEs críticas ou de alta prioridade** em serviços expostos em rede (Outlook, Exchange, DHCP, MSMQ, QUIC, Remote Desktop Gateway, AD DS, Hyper-V, SharePoint e SQL Server). Também cobre as mudanças de hardening e os fins de suporte que chegaram junto com a atualização.

Para cada CVE detalhada, os campos CVSS, vetor, CWE, status de exploração e índice de explorabilidade foram conferidos diretamente no registro oficial do **Microsoft Security Response Center (MSRC)**.

Principais conclusões

- **CVE-2026-96951 (Windows Shell) está sendo explorada ativamente.** Ela remove a proteção Mark of the Web, que é a base dos alertas do SmartScreen, do Modo de Exibição Protegido do Office e do bloqueio de macros. Foi incluída no catálogo KEV da CISA, com prazo federal de correção até 16/10/2026.
- **Outlook: cinco RCEs críticas (CVSS 9,8)** acionadas apenas pela **visualização** de um e-mail no Painel de Leitura, sem abrir nem clicar. A Microsoft não as marca como exploradas, mas e-mail é o principal vetor de entrada em empresas.
- **Serviços de rede do Windows:** RCEs críticas sem autenticação no DHCP Server (até 9,8), Message Queuing (9,8), QUIC (9,8), Remote Desktop Gateway (8,1) e Active Directory Domain Services (8,1, “Exploitation More Likely”).
- **Fins de suporte em 13/10/2026:** Windows 11 24H2 Home/Pro e Windows 10 LTSB 2016 receberam a última atualização. Windows Server 2022 saiu do suporte principal, e Windows 11 23H2 Enterprise/Education termina em 10/11/2026.
- **Hardening que pode quebrar coisas:** a restrição de NTLMv1 pode derrubar Wi-Fi, Ethernet e VPN que usem MS-CHAPv2, e o enforcement do ACL do contêiner DKM do AD FS (CVE-2026-56155) está ativo por padrão.
- **Priorize pelo risco, não pelo volume.** Segundo a Fortra, menos de 1% das CVEs da Microsoft em 2026 está no KEV. Corrija primeiro o que é explorado, exposto à internet e sem autenticação.

Visão geral das CVEs analisadas

CVE	Produto	Tipo	Sev. / CVSS	Status
CVE-2026-96951	Windows Shell	Bypass de recurso (MOTW)	Imp. 8.8	**Explorada**
CVE-2026-108398	.NET Framework	Bypass de recurso (WDAC)	Imp. 8.8	Divulgada
CVE-2026-92707	MessagePack-CSharp	Negação de serviço	Mod. 5.3	Divulgada
CVE-2026-70242	Outlook	RCE (Painel de Leitura)	Crít. 9.8	—
CVE-2026-70291	Outlook	RCE (Painel de Leitura)	Crít. 9.8	—
CVE-2026-96934	DHCP Server	RCE sem autenticação	Crít. 9.8	—
CVE-2026-88117	DHCP Server	RCE (condição de corrida)	Crít. 8.1	—
CVE-2026-70250	DHCP Client	RCE em rede adjacente	Crít. 8.8	—
CVE-2026-100202	Message Queuing	RCE sem autenticação	Crít. 9.8	—
CVE-2026-108460	Message Queuing	RCE (condição de corrida)	Crít. 8.1	—
CVE-2026-105016	Microsoft QUIC	RCE sem autenticação	Crít. 9.8	—
CVE-2026-100219	Microsoft QUIC	RCE sem autenticação	Crít. 9.8	—
CVE-2026-70187	RD Gateway	RCE sem autenticação	Crít. 8.1	—
CVE-2026-70229	AD Domain Services	RCE sem autenticação	Crít. 8.1	Mais provável
CVE-2026-70571	Exchange Server	RCE via e-mail	Crít. 8.1	Mais provável
CVE-2026-102866	SharePoint	Elevação de privilégio	Crít. 8.1	—
CVE-2026-102214	Hyper-V	Escape de VM	Crít. 8.8	—
CVE-2026-105733	Hyper-V	Escape de VM aninhada	Crít. 8.8	—
CVE-2026-70279	Exchange Server	Spoofing (XSS)	Imp. 9.3	Mais provável
CVE-2026-96940	Exchange Server	Elevação (acesso a caixas)	Imp. 8.8	Mais provável
CVE-2026-65674	SQL Server	RCE autenticada	Imp. 8.8	—
CVE-2026-88159	BITS	RCE autenticada	Imp. 8.8	Mais provável
CVE-2026-102217	WebDAV (IIS)	Elevação → código no app pool	Imp. 8.8	Mais provável

“Mais provável” = índice de explorabilidade “Exploitation More Likely” no MSRC. “—” = não explorada, não divulgada e “Exploitation Less Likely”.

2. Contexto e conceitos

Os números do mês

A Microsoft não publica uma contagem oficial; os totais variam porque cada empresa decide se inclui as correções de serviços de nuvem e as CVEs publicadas antes do dia 13. A distribuição por tipo de impacto, segundo a SecPod (base de 1.407 CVEs), foi:

Tipo de impacto	Total	Críticas	Importantes
Elevação de privilégio	673 (47,8%)	11	662
Execução remota de código	315 (22,4%)	65	250
Divulgação de informação	252 (17,9%)	0	252
Negação de serviço	71 (5,0%)	0	71
Bypass de recurso de segurança	40 (2,8%)	0	40
Adulteração (tampering)	29 (2,1%)	0	29
Spoofing	27 (1,9%)	2	25

A contagem de críticas também diverge: Tenable fala em 69, BleepingComputer em 70 e SecPod em 78. A explicação mais citada para o volume é a **descoberta de vulnerabilidades assistida por IA**. Dustin Childs, da Zero Day Initiative, resumiu que a IA “não cria esses bugs do nada”, mas reduz o tempo até alguém percebê-los. Segundo o Dark Reading, o zero-day do Windows Shell foi atribuído a uma descoberta feita com o Claude, da Anthropic.

Ao lado das CVEs, a Microsoft testou os **“risk cohorts”**: 15 agrupamentos de CVEs que pedem a mesma avaliação de ambiente, como “sistemas de arquivos, armazenamento e backup” (136) ou “documentos do Office e clientes de e-mail” (135). O MSRC deixou claro que isso **não** é um novo sistema de priorização e que cada CVE deve continuar sendo avaliada por exploração, gravidade, vetor e interação do usuário.

Glossário

Termo	Significado
Patch Tuesday	Segunda terça-feira do mês, quando a Microsoft publica as atualizações de segurança. Correções urgentes podem sair fora desse ciclo (out-of-band).
Security Update Guide (SUG)	Portal oficial do MSRC com o registro de cada CVE: CVSS, CWE, FAQ, produtos afetados, KBs e índice de explorabilidade.
Gravidade Microsoft	Escala própria: **Crítica** (exploração sem ação do usuário, geralmente RCE), **Importante**, **Moderada** e **Baixa**. Não é igual à nota CVSS — por isso uma CVE “Importante” pode ter CVSS 9,3.
Exploitability Index	Previsão da Microsoft: “Exploitation Detected” (já explorada), “More Likely” (provável em até 30 dias) ou “Less Likely”.
Vetor temporal E:U / E:F	Maturidade do exploit no CVSS: U = sem código conhecido; F = exploit funcional existe.
Mark of the Web (MOTW)	Marca que o Windows grava em arquivos vindos da internet. SmartScreen, Modo de Exibição Protegido do Office, bloqueio de macros, Smart App Control e o aviso do Attachment Manager dependem dela.
WDAC	Windows Defender Application Control: política que define quais aplicativos e bibliotecas podem executar.
Painel de Leitura (Preview Pane)	Área do Outlook que mostra o e-mail sem abri-lo. Quando é vetor de ataque, basta o e-mail ser exibido.
S:C (escopo alterado)	O impacto ultrapassa o componente vulnerável — por exemplo, código numa VM afetando o host.
CISA KEV	Catálogo da agência americana CISA com vulnerabilidades comprovadamente exploradas; órgãos federais têm prazo para corrigir.
ESU	Extended Security Updates: programa pago (ou gratuito em casos específicos) de atualizações após o fim do suporte.

3. Zero-days

3.1 CVE-2026-96951 — Windows Shell: bypass do Mark of the Web (explorada)

CVE-2026-96951	IMPORTANTE · CVSS 8.8
Título oficial	Windows Shell Security Feature Bypass Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H/E:F/RL:O/RC:C`
Fraqueza (CWE)	CWE-77: injeção de comando (neutralização imprópria de elementos especiais)
Explorada / divulgada	**Sim (Exploitation Detected)** / Não
Índice de explorabilidade	Exploitation Detected — exploit funcional (E:F)
Publicado em	13/10/2026

O que identifica

Segundo o MSRC, há uma **injeção de comando no Windows Shell** que permite a um atacante não autorizado contornar um recurso de segurança pela rede. O recurso burlado é o **Mark of the Web**: um arquivo vindo da internet passa a ser tratado como se tivesse sido criado localmente, e o Windows deixa de exibir os avisos que dependem dessa marca (SmartScreen, Modo de Exibição Protegido do Office, bloqueio de macros, Smart App Control e o alerta do Attachment Manager).

Como é explorada (FAQ oficial): o atacante envia um arquivo especialmente preparado por e-mail ou mensagem instantânea e precisa convencer a vítima a agir — clicar no link ou abrir o anexo. É a **terceira falha do Windows Shell explorada em 2026**, depois da CVE-2026-21510 (fevereiro) e da CVE-2026-32202 (abril), segundo a Tenable. A imprensa relata que o Outlook.com recebeu uma correção do lado do serviço semanas antes.

Impacto

Por si só, não executa código: ela tira a “trava de segurança” para que um anexo malicioso rode sem alertas. Por isso é usada no início de campanhas de phishing, encadeada com executáveis, atalhos ou documentos com macros. O MSRC não divulgou detalhes da campanha nem quem a descobriu.

Correção e mitigação

Instalar a atualização cumulativa de outubro de 2026 (ex.: Windows 11 KB5127648 / KB5126653; Windows 10 ESU KB5126657). A CISA a incluiu no KEV com prazo federal até 16/10/2026. Segundo a imprensa, o Windows Server 2012 (não R2) não recebe correção. Paliativos enquanto não atualiza (não oficiais): bloquear no gateway de e-mail anexos de risco (.lnk, .url, .iso, .vhd, .hta, .js), aplicar regras ASR do Defender contra conteúdo executável vindo de e-mail e reforçar o treinamento contra phishing.

3.2 CVE-2026-108398 — .NET Framework: bypass do WDAC (divulgada)

CVE-2026-108398	IMPORTANTE · CVSS 8.8
Título oficial	.NET Framework Security Feature Bypass Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-426: caminho de busca não confiável
Explorada / divulgada	Não / **Sim (divulgada publicamente)**
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Um **caminho de busca não confiável** no .NET Framework permite que um atacante autenticado localmente contorne o **Windows Defender Application Control**. Pelo FAQ oficial, o atacante coloca um assembly .NET preparado no sistema e o registra para ser carregado por um processo protegido, executando código dentro desse processo, sem interação do usuário.

A BleepingComputer credita a descoberta a **James Forshaw (Google Project Zero)**. O escopo alterado (S:C) indica que o impacto ultrapassa o componente vulnerável.

Impacto

É uma técnica de **pós-exploração**: exige acesso local, mas permite rodar código não aprovado em ambientes que confiam no WDAC como barreira (estações administrativas, servidores endurecidos, quiosques).

Correção e mitigação

Atualizar o .NET Framework pelos pacotes de outubro. A Action1 recomenda monitorar o carregamento suspeito de assemblies por processos protegidos (eventos do CodeIntegrity e Sysmon ID 7).

3.3 CVE-2026-92707 — MessagePack-CSharp: negação de serviço (divulgada)

CVE-2026-92707	MODERADA · CVSS 5.3
Título oficial	MessagePack-CSharp Denial of Service Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`
Fraqueza (CWE)	CWE-1325: alocação sequencial de memória sem controle
Explorada / divulgada	Não / **Sim (divulgada publicamente)**
Índice de explorabilidade	Não informado; CNA: GitHub
Publicado em	13/10/2026

O que identifica

Vulnerabilidade na biblioteca de código aberto MessagePack-CSharp, usada por produtos Microsoft. Desserializar dados não confiáveis como `object` pode provocar alocações de memória enormes. A revisão 1.1 (15/10/2026) acrescentou links de KB para o .NET 11, sem alterar os builds corrigidos.

Impacto

Negação de serviço remota sem autenticação em aplicações que desserializam MessagePack de fontes externas.

Correção e mitigação

Atualizar o pacote NuGet para 2.5.303+ ou 3.1.9+ (segundo a SecPod) — **fora** do pacote cumulativo do Windows, ou seja, os desenvolvedores precisam atualizar a dependência e publicar a aplicação novamente.

4. CVEs críticas

Todas as CVEs desta seção estão marcadas no MSRC como **não exploradas e não divulgadas**. A ordem segue a exposição típica: primeiro o que chega por e-mail, depois serviços de rede, e por fim virtualização e colaboração.

4.1 CVE-2026-70242 — Outlook: RCE pelo Painel de Leitura

CVE-2026-70242	CRÍTICA · CVSS 9.8
Título oficial	Microsoft Office Outlook Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-122: estouro de buffer no heap
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Um **estouro de buffer no heap** no Outlook. Pelo FAQ do MSRC, o atacante envia um e-mail especialmente preparado e “simplesmente visualizar a mensagem no Painel de Leitura” dispara a falha, sem que o destinatário abra o e-mail ou clique em nada. Não há exigência de autenticação nem de interação.

O mesmo padrão aparece em outras quatro CVEs críticas do Outlook: CVE-2026-70291 (conferida no MSRC: 9,8, CWE-122, “Sim, o Painel de Visualização é um vetor de ataque”), CVE-2026-88156, CVE-2026-97016 e CVE-2026-97749 (listadas pela SecPod como RCE pelo Painel de Leitura).

Impacto

Execução de código no computador do usuário com os privilégios dele, apenas por receber e exibir o e-mail. É o tipo de falha com maior potencial de exploração em massa, mesmo com índice “Less Likely”.

Correção e mitigação

Atualizar o Office/Outlook (Microsoft 365 Apps pelo canal de atualização, ou o MSI correspondente). Paliativos não oficiais: configurar o Outlook para ler e-mails em texto sem formatação (GPO “Ler todo e-mail padrão em texto sem formatação”) e desativar o Painel de Leitura até a correção chegar a todas as estações.

4.2 CVE-2026-96934 — DHCP Server: RCE sem autenticação

CVE-2026-96934	CRÍTICA · CVSS 9.8
Título oficial	Windows DHCP Server Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-416: uso após liberação (use-after-free)
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Um **use-after-free no serviço DHCP Server** do Windows. Um atacante sem credenciais envia um pacote preparado ao serviço DHCP e executa código no servidor.

Ao todo são cinco RCEs críticas no DHCP Server neste mês (CVE-2026-96934, 88117, 88119, 88120 e 88171). A **CVE-2026-88117** (CVSS 8,1, também use-after-free) exige vencer uma condição de corrida, por isso tem complexidade alta. Há ainda a **CVE-2026-70250 no DHCP Client** (CVSS 8,8, AV:A — rede adjacente; CWE-416 e CWE-362): um atacante na mesma rede local, por exemplo com um servidor DHCP falso, pode executar código nas estações.

Impacto

Servidores DHCP costumam ser controladores de domínio ou servidores de infraestrutura: comprometê-los dá ao atacante uma posição privilegiada na rede inteira.

Correção e mitigação

Atualizar os servidores com a função DHCP. Paliativos não oficiais: garantir que as portas UDP 67/68 do servidor não fiquem expostas fora das redes que ele atende e ativar DHCP Snooping nos switches (também protege contra o cenário do DHCP Client).

4.3 CVE-2026-100202 — Message Queuing: RCE sem autenticação

CVE-2026-100202	CRÍTICA · CVSS 9.8
Título oficial	Windows Message Queuing Queue Manager Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-416: uso após liberação
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Pelo FAQ, o atacante envia uma mensagem preparada pela rede a um sistema com o serviço **MSMQ** ativo; ao processá-la, o Queue Manager corrompe a memória e permite executar código. A **CVE-2026-108460** (CVSS 8,1, use-after-free) é similar, mas depende de vencer uma condição de corrida.

O MSMQ não vem ativo por padrão, mas é instalado por alguns aplicativos de negócio e pelo Exchange; ele escuta na porta TCP 1801.

Impacto

RCE sem autenticação em qualquer máquina com MSMQ alcançável pela rede.

Correção e mitigação

Atualizar. Paliativo histórico da Microsoft para falhas de MSMQ (não citado neste aviso): verificar se o serviço “Message Queuing” existe e, se não for usado, desativá-lo; caso contrário, bloquear a porta TCP 1801 de origens não confiáveis.

4.4 CVE-2026-105016 — Microsoft QUIC: RCE sem autenticação

CVE-2026-105016	CRÍTICA · CVSS 9.8
Título oficial	Microsoft QUIC Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-122: estouro de buffer no heap
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Um **estouro de buffer no heap** na implementação QUIC da Microsoft (MsQuic), o protocolo sob o HTTP/3 e o SMB sobre QUIC. Um atacante não autenticado envia um pacote preparado ao serviço e executa código. A **CVE-2026-100219** (também 9,8, mas use-after-free) tem o mesmo cenário.

Segundo o Darkreading, o MsQuic está presente no Windows 11, no Windows Server, no .NET e no Visual Studio — por isso as correções vêm tanto pelo Windows Update quanto pelas atualizações do .NET.

Impacto

RCE remota sem autenticação em servidores que expõem HTTP/3 (IIS/HTTP.sys, Kestrel) ou SMB sobre QUIC à internet.

Correção e mitigação

Atualizar o Windows e os runtimes .NET (e reconstruir/republicar aplicações self-contained). Paliativo não oficial: desabilitar temporariamente o HTTP/3 no servidor e bloquear UDP 443 de entrada onde não for necessário.

4.5 CVE-2026-70187 — Remote Desktop Gateway: RCE sem autenticação

CVE-2026-70187	CRÍTICA · CVSS 8.1
Título oficial	Windows Remote Desktop Services Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-416: uso após liberação
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Um **use-after-free no serviço Remote Desktop Gateway**. Um atacante não autenticado envia um pacote preparado e pode executar código. A complexidade é alta: o FAQ diz que a exploração exige conhecimento profundo do sistema-alvo e depende do ambiente.

Impacto

O RD Gateway costuma ficar **exposto à internet** justamente para dar acesso remoto, o que o torna alvo prioritário, apesar da complexidade.

Correção e mitigação

Atualizar os servidores RD Gateway com prioridade. Paliativos: restringir o acesso por VPN ou por lista de IPs e monitorar falhas e reinícios do serviço TSGateway.

4.6 CVE-2026-70229 — Active Directory Domain Services: RCE

CVE-2026-70229	CRÍTICA · CVSS 8.1
Título oficial	Windows Active Directory Domain Services Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-863: autorização incorreta
Explorada / divulgada	Não / Não
Índice de explorabilidade	**Exploitation More Likely**
Publicado em	13/10/2026

O que identifica

Uma falha de **autorização incorreta no AD DS** permite que um atacante não autenticado envie um pacote preparado ao serviço e execute código. Pelo FAQ, a exploração exige configurações de rede e condições de tempo específicas e só foi observada em cenários limitados — daí a complexidade alta.

Impacto

Execução de código num controlador de domínio significa, na prática, comprometimento de todo o domínio. É uma das poucas críticas com índice “More Likely”.

Correção e mitigação

Atualizar **todos** os controladores de domínio primeiro. Garantir que DCs não sejam alcançáveis pela internet e segmentar o acesso a eles a partir das estações.

4.7 CVE-2026-70571 — Exchange Server: RCE via e-mail

CVE-2026-70571	CRÍTICA · CVSS 8.1
Título oficial	Microsoft Exchange Server Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-121: estouro de buffer na pilha
Explorada / divulgada	Não / Não
Índice de explorabilidade	**Exploitation More Likely**
Publicado em	13/10/2026

O que identifica

Um **estouro de buffer na pilha** no Exchange. Um atacante não autenticado envia um e-mail preparado que aciona um processo interno de **conversão de conteúdo** no servidor, sem interação de usuário. O FAQ diz que a exploração exige conhecimento profundo do ambiente-alvo.

Impacto

Execução de código no servidor Exchange — que concentra todo o e-mail da organização e tem altos privilégios no Active Directory.

Correção e mitigação

Aplicar o Security Update de outubro do Exchange (2016, 2019 ou Subscription Edition). O Exchange Online é corrigido pela Microsoft. Seguir também os itens 5.1 e 5.2.

4.8 CVE-2026-102866 — SharePoint: elevação de privilégio

CVE-2026-102866	CRÍTICA · CVSS 8.1
Título oficial	Microsoft Office SharePoint Elevation of Privilege Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-347: verificação imprópria de assinatura criptográfica
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

O SharePoint não verifica corretamente a assinatura de um **proof token**. Um atacante não autenticado que obtenha um token válido de um usuário-alvo pode alterá-lo, enviá-lo ao servidor e se autenticar como aquele usuário. O Painel de Visualização não é vetor.

Impacto

Acesso e modificação do conteúdo do usuário personificado; se o alvo for administrador do site, o impacto cresce.

Correção e mitigação

Atualizar o SharePoint Server (Subscription Edition, 2019, 2016). O SharePoint Online é corrigido pela Microsoft.

4.9 CVE-2026-102214 — Hyper-V: escape da VM para o host

CVE-2026-102214	CRÍTICA · CVSS 8.8
Título oficial	Windows Hyper-V Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-416: uso após liberação
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Apesar do título “Remote”, o vetor é local: um atacante que roda uma aplicação preparada **dentro de uma VM convidada** faz o host Hyper-V executar código arbitrário. O escopo alterado (S:C) indica a quebra da fronteira VM → host.

A **CVE-2026-105733** (8,8, CWE-1419) é parecida, mas em virtualização aninhada: escapa de uma VM aninhada para a VM que funciona como host.

Impacto

Quem controla uma VM, mesmo com baixo privilégio, pode comprometer o host e todas as outras VMs dele. É crítico em provedores, laboratórios e VDI.

Correção e mitigação

Atualizar os hosts Hyper-V (requer reinício — planejar migração ao vivo das VMs).

5. CVEs “Importantes” de alta prioridade

A gravidade “Importante” não significa baixo risco: estas têm CVSS alto ou índice “Exploitation More Likely”.

5.1 CVE-2026-70279 — Exchange: spoofing via XSS

CVE-2026-70279	IMPORTANTE · CVSS 9.3
Título oficial	Microsoft Exchange Server Spoofing Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-79: cross-site scripting
Explorada / divulgada	Não / Não
Índice de explorabilidade	**Exploitation More Likely**
Publicado em	13/10/2026

O que identifica

Um **XSS** no Exchange (provavelmente no OWA ou no ECP). O atacante envia um link preparado e convence o usuário a clicar; o script roda no navegador da vítima com as permissões dela. O escopo alterado reflete que a falha está no servidor web, mas o código executa no navegador.

Impacto

Se a vítima for administradora, o atacante pode acessar ou modificar dados da organização.

Correção e mitigação

Atualizar o Exchange. Reforçar o alerta contra links suspeitos para contas administrativas e usar contas separadas para administração.

5.2 CVE-2026-96940 — Exchange: acesso a caixas de outros usuários

CVE-2026-96940	IMPORTANTE · CVSS 8.8
Título oficial	Microsoft Exchange Server Elevation of Privilege Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-1390: autenticação fraca
Explorada / divulgada	Não / Não
Índice de explorabilidade	**Exploitation More Likely**
Publicado em	02/10/2026 (antes do Patch Tuesday)

O que identifica

Publicada em 02/10/2026 junto com as “September 2026 v2 Exchange Server Security Updates”. Um atacante autenticado na rede pode **acessar as caixas de correio de outros usuários da mesma organização** e ler e-mails e anexos; não ultrapassa a fronteira entre tenants.

Impacto

Vazamento de e-mails internos por qualquer usuário com conta válida — muito útil para um atacante que já roubou uma credencial comum.

Correção e mitigação

No Exchange Online a Microsoft já corrigiu do lado do serviço. Em servidores locais e híbridos, instalar os updates de 02/10 (KB5129955 a KB5129958, segundo a Nightwing) além dos de 13/10.

5.3 CVE-2026-65674 — SQL Server: RCE autenticada

CVE-2026-65674	IMPORTANTE · CVSS 8.8
Título oficial	Microsoft SQL Server Remote Code Execution Vulnerability
Vetor CVSS 3.1	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C`
Fraqueza (CWE)	CWE-502: desserialização de dados não confiáveis
Explorada / divulgada	Não / Não
Índice de explorabilidade	Exploitation Less Likely
Publicado em	13/10/2026

O que identifica

Um atacante **autenticado** envia uma consulta preparada que provoca corrupção de memória e execução de código no servidor. O FAQ traz a tabela de versões (ex.: SQL Server 2025 CU9 → KB5126967; SQL Server 2019 RTM → KB5128495).

Impacto

Qualquer conta com login no SQL — inclusive a de uma aplicação web comprometida por SQL injection — pode virar execução de código no servidor de banco.

Correção e mitigação

Identificar a versão exata (KB 321185) e aplicar a GDR ou CU de outubro correspondente. Não há contorno oficial.

5.4 Outras “Importantes” com exploração mais provável

CVE	Componente / CVSS	O que identifica
CVE-2026-88159	BITS — 8.8 (PR:L)	RCE no Background Intelligent Transfer Service por usuário autenticado. O registro oficial está inconsistente: a descrição fala em use-after-free e a CWE em leitura fora dos limites (CWE-125).
CVE-2026-102217	WebDAV — 8.8 (PR:L)	CWE-41 (equivalência de caminhos). Um atacante autenticado envia uma requisição preparada e executa código no contexto do pool de aplicativos do IIS.
CVE-2026-100214	Dynamics 365 Business Central — 8.8	RCE (dado da Tenable, não conferido no MSRC).
CVE-2026-69918	Windows Core Messaging — 7.8/8.8	Elevação de privilégio (Tenable).
CVE-2026-69673, 69718, 69733, 69783, 69882	Windows Update — 7.8	Cinco elevações de privilégio locais no Windows Update (Tenable).
CVE-2026-69880, 69926	Desktop Window Manager — 7.8	Elevação local de privilégio, classe historicamente explorada em ataques reais (Tenable).
CVE-2026-69923	Windows AI — 7.8	Elevação local de privilégio (Tenable).
CVE-2026-70054	Windows NetBIOS — 7.8	Elevação local de privilégio (Tenable).

6. Mudanças de hardening e fins de suporte

O Windows message center publicou, junto com a atualização, mudanças de comportamento que impactam diretamente o suporte técnico:

Data	Mudança	O que fazer
13/10	**NTLMv1:** Windows 11 (24H2, 25H2, 26H2) e Server 2025 passam a restringir por padrão credenciais de SSO derivadas de NTLMv1 em dispositivos sem Credential Guard.	Pode quebrar Wi-Fi, Ethernet e VPN que usam MS-CHAPv2 (ex.: PEAP com senha). Migrar para autenticação por certificado (EAP-TLS). Ver KB5066470. A Microsoft afirma que isso não é um “known issue”, e sim uma mudança intencional.
13/10	**AD FS — ACL do contêiner DKM** em modo de enforcement (CVE-2026-56155).	A correção roda por padrão nas versões suportadas; Windows Server 2012/2012 R2 exigem correção manual.
13/10	**ReFS em mídia removível:** fase de auditoria.	Enforcement em janeiro de 2027 — revisar logs.
13/10	**Administrator protection** habilitado nas baselines de segurança do Windows 11.	Testar ferramentas administrativas que dependem de elevação silenciosa.
08/10	**Rotação dos certificados do Windows Update** (expiram em 17/05 e 19/06/2027).	Windows 11 24H2 e Server 2025 precisam da atualização de set/2025 ou posterior; demais versões, de jul/2026 ou posterior. Sem isso, a máquina deixa de receber atualizações.
13/10	Possível reinício extra durante a instalação em alguns dispositivos, após a atualização do certificado do Secure Boot.	Avisar os usuários; não interromper a instalação.

Fins de suporte

- **13/10/2026 — última atualização:** Windows 11 24H2 Home e Pro (atualizar para 25H2/26H2 pelo Windows Update) e Windows 10 Enterprise LTSB 2016 / IoT LTSB 2016.
- **13/10/2026:** Windows Server 2022 sai do suporte principal (segue com atualizações de segurança até 14/10/2031). Office 2021 e Office LTSC 2021 encerram o suporte, segundo a Tenable.
- **Windows Server 2012 e 2012 R2:** o ESU terminou, segundo a Tenable; sem atualizações, ficam expostos a todas as CVEs deste mês.
- **Próximos:** Windows 11 23H2 Enterprise/Education em 10/11/2026; Windows Server 2016 e Windows 10 Enterprise LTSC 2021 em 12/01/2027.
- **Windows 10 doméstico:** só recebe correções quem está inscrito no ESU para consumidores (exige 22H2).

7. Recomendações práticas para o suporte

Ordem de prioridade sugerida

Prioridade	O quê	Por quê
1 — imediato	Todas as estações e servidores: atualização cumulativa de outubro (CVE-2026-96951)	Explorada ativamente, entra por phishing.
1 — imediato	Office/Outlook em todas as estações (CVE-2026-70242 + 4)	RCE só por exibir um e-mail.
2 — até 48 h	Controladores de domínio (AD DS, DHCP), Exchange, RD Gateway	Sem autenticação, alto impacto, alguns com exploração mais provável.
2 — até 48 h	Servidores com HTTP/3, SMB sobre QUIC ou MSMQ expostos	RCE 9,8 sem autenticação.
3 — janela normal	Hyper-V, SharePoint, SQL Server, .NET/MessagePack, demais CVEs	Exigem acesso prévio, autenticação ou condições específicas.

Checklist de atendimento

- Verificar se a atualização foi instalada: `winver` (número de build) ou, em PowerShell, `Get-HotFix | Sort-Object InstalledOn -Descending | Select -First 5`. No WSUS/Intune, conferir o relatório de conformidade.
- Confirmar o reinício — a correção só vale depois dele.
- Office: `Arquivo > Conta > Opções de Atualização > Atualizar Agora` no Microsoft 365 Apps.
- Exchange local: executar o Health Checker da Microsoft para validar o nível de atualização.
- Listar máquinas sem suporte (Windows 10 sem ESU, Server 2012, Windows 11 24H2 Home/Pro) e abrir plano de migração.
- Se, após a atualização, usuários perderem Wi-Fi ou VPN corporativa, suspeitar primeiro do hardening de NTLMv1 / MS-CHAPv2 antes de tratar como defeito.

Detecção (Blue Team)

- Anexos executados a partir de pastas de e-mail ou de download **sem** o fluxo de dados alternativo `Zone.Identifier` (sinal de bypass de MOTW).
- Processos filhos inesperados de `OUTLOOK.EXE`, `explorer.exe` abrindo scripts, ou processos do Office iniciando `cmd`/`powershell`.
- Crashes e reinícios de `dhcpserver`, `mqsvc.exe` (MSMQ), `TSGateway` e do serviço de transporte do Exchange no log de eventos (IDs 7031/7034) — podem indicar tentativas de exploração.
- Carregamento de assemblies .NET não assinados por processos protegidos e eventos do CodeIntegrity (CVE-2026-108398).
- Acessos a caixas de correio de terceiros no log de auditoria do Exchange (CVE-2026-96940).

Apêndice A — Outras CVEs críticas citadas

CVEs críticas listadas por pesquisadores mas não detalhadas acima. Itens marcados com * não tiveram o registro conferido individualmente no MSRC para este relatório.

CVE	Produto	Tipo
CVE-2026-88119 *, 88120 *, 88171 *	Windows DHCP Server	RCE (SecPod)
CVE-2026-88156 *, 97016 *, 97749 *	Microsoft Outlook	RCE pelo Painel de Leitura (SecPod)
CVE-2026-96222 *, 108131 *	AD FS	Spoofing (BleepingComputer)
CVE-2026-83943 *	Azure API Center	Divulgação de informação — serviço de nuvem
CVE-2026-77900 *	Azure App Service	RCE — serviço de nuvem
CVE-2026-83947 *	Azure Event Grid	Spoofing — serviço de nuvem
CVE-2026-69435 *	Azure SRE Agent	Elevação de privilégio — serviço de nuvem
CVE-2026-62840 *, 78663 *, 83632 *	Azure Linux (Mariner): kernel Linux, Go net/http HTTP/2, Apache Thrift	Componentes de terceiros corrigidos na distribuição da Microsoft

CVEs de serviços de nuvem (Azure, Outlook.com) são corrigidas pela própria Microsoft e normalmente não exigem ação do cliente; elas aparecem no Security Update Guide por transparência.

Produtos com mais CVEs no mês (Tenable)

Produto	CVEs	Produto	CVEs
Office Excel	69	Office SharePoint	34
Role: DNS Server	52	Windows Search	29
Windows Kernel	46	Windows NTFS	26
Windows Installer	38	.NET	25
Win32 Kernel Subsystem	36	Word / SQL Server / WER	22 cada

Fontes de pesquisa

Consultadas em 22/10/2026. Os registros do MSRC (API pública do Security Update Guide) são a fonte primária de CVSS, CWE, status e FAQ.

Fontes oficiais da Microsoft

[1] Microsoft Security Update Guide (portal)
https://msrc.microsoft.com/update-guide

[2] MSRC — registro oficial da CVE-2026-96951
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-96951

[3] MSRC — registro oficial da CVE-2026-108398
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-108398

[4] MSRC — registro oficial da CVE-2026-92707
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-92707

[5] MSRC — registro oficial da CVE-2026-70242
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70242

[6] MSRC — registro oficial da CVE-2026-70291
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70291

[7] MSRC — registro oficial da CVE-2026-96934
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-96934

[8] MSRC — registro oficial da CVE-2026-88117
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-88117

[9] MSRC — registro oficial da CVE-2026-70250
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70250

[10] MSRC — registro oficial da CVE-2026-100202
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-100202

[11] MSRC — registro oficial da CVE-2026-108460
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-108460

[12] MSRC — registro oficial da CVE-2026-105016
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-105016

[13] MSRC — registro oficial da CVE-2026-100219
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-100219

[14] MSRC — registro oficial da CVE-2026-70187
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70187

[15] MSRC — registro oficial da CVE-2026-70229
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70229

[16] MSRC — registro oficial da CVE-2026-70571
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70571

[17] MSRC — registro oficial da CVE-2026-102866
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-102866

[18] MSRC — registro oficial da CVE-2026-102214
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-102214

[19] MSRC — registro oficial da CVE-2026-105733
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-105733

[20] MSRC — registro oficial da CVE-2026-70279
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70279

[21] MSRC — registro oficial da CVE-2026-96940
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-96940

[22] MSRC — registro oficial da CVE-2026-65674
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-65674

[23] MSRC — registro oficial da CVE-2026-88159
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-88159

[24] MSRC — registro oficial da CVE-2026-102217
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-102217

[25] Windows message center (Microsoft Learn)
https://learn.microsoft.com/en-us/windows/release-health/windows-message-center

Pesquisadores e imprensa especializada

[26] Tenable — Microsoft's October 2026 Patch Tuesday Addresses 1,407 CVEs
https://www.tenable.com/blog/microsofts-october-2026-patch-tuesday-addresses-1407-cves-cve-2026-96951

[27] SecPod — October 2026 Patch Tuesday: 1,407 CVEs, Exploited Zero-Day
https://www.secpod.com/learn/security-research/two-zero-days-1-407-microsoft-flaws-fixed-october-2026-patch-tuesday-delivers-a-massive-update

[28] BleepingComputer — Microsoft October 2026 Patch Tuesday fixes 1,411 flaws, 3 zero-days
https://www.bleepingcomputer.com/news/microsoft/microsoft-october-2026-patch-tuesday-fixes-1-411-flaws-3-zero-days/

[29] Dark Reading — Zero-Days Lurk in Microsoft's Overgrown October Patch Tuesday
https://www.darkreading.com/vulnerabilities-threats/zero-days-microsoft-october-patch-tuesday

[30] Tech Times — Microsoft Patch Tuesday October 2026: Record 1,413 CVEs
https://www.techtimes.com/articles/329061/20261015/microsoft-patch-tuesday-october-2026-record-1413-cves-one-already-under-attack.htm

[31] iTnews — Microsoft floats "risk cohorts" as patch load hits record size
https://www.itnews.com.au/news/microsoft-floats-risk-cohorts-as-patch-load-hits-record-size-629624

[32] NeoTeo — Reports identify three zero-days in Microsoft's October 2026 Patch Tuesday
https://www.neoteo.com/en/reports-identify-three-zero-days-in-microsofts-october-2026-patch-tuesday